

politica-eipd-grt

security-system/politica-eipd-grt.docx

Objetivo

La presente Política para la Elaboración de Evaluaciones de Impacto en la Protección de Datos Personales (en adelante, la “Política”) tiene por objeto establecer los lineamientos y metodología que Grünenthal de México S.A. de C.V. (en adelante, “Grünenthal”) deberá observar para identificar, evaluar y mitigar los riesgos asociados a tratamientos de datos personales que, por su naturaleza, alcance, contexto o finalidades, puedan representar un alto riesgo para los derechos y libertades de los Titulares.

La Evaluación de Impacto en la Protección de Datos Personales (en adelante, “EIPD”) constituye una buena práctica en materia de rendición de cuentas, al permitir al Responsable documentar las medidas implementadas para garantizar el cumplimiento de la Ley Federal de Protección de Datos Personales en Posesión de los Particulares (en adelante, la “LFPDPPP”).

Si bien la elaboración de una EIPD no es una obligación legal exigible de forma general en el marco normativo mexicano, Grünenthal reconoce su utilidad como herramienta preventiva y de gestión de riesgos, que permite evidenciar un cumplimiento proactivo del principio de responsabilidad, así como reforzar los deberes de confidencialidad y seguridad establecidos en la LFPDPPP.

Asimismo, de acuerdo con la política global de protección de datos personales de Grünenthal, realizar esta evaluación es obligatorio para ciertos casos que pudiera representar ciertos riesgos a las libertades y derechos de los titulares. Por ende, la implementación de esta política es obligatoria.

En particular, esta Política deberá aplicarse previo al diseño, desarrollo o implementación de nuevos productos, servicios, tecnologías, modelos de negocio o esquemas operativos que impliquen el tratamiento de datos personales en condiciones que pudieran generar un riesgo elevado para los Titulares, en atención a los principios de privacidad desde el diseño (privacy by design) y privacidad por defecto (privacy by default).

A nivel internacional, la práctica de realizar evaluaciones de impacto encuentra sustento en los Estándares de Protección de Datos Personales para los Estados Iberoamericanos, los cuales, en su artículo 41.1, establecen que, cuando el Responsable pretenda llevar a cabo un tratamiento que pueda entrañar un alto riesgo para los derechos de los Titulares, deberá realizar una EIPD de forma previa a su implementación. Asimismo, el artículo 38 de dichos estándares reconoce la importancia de adoptar los enfoques de protección de datos por diseño y por defecto como medidas estructurales de cumplimiento.

La presente Política contiene la metodología que Grünenthal adoptará para:

Identificar tratamientos de datos personales de alto riesgo.

Desplegar mecanismos de evaluación y mitigación preventiva.

Documentar las decisiones tomadas respecto a la viabilidad del tratamiento.

Atender las mejores prácticas, recomendaciones de la autoridad de protección de datos en México y estándares internacionales aplicables en la materia.

Alcance

Las directrices y metodología establecidas en la presente Política aplican a todas las áreas de Grünenthal que lleven a cabo tratamientos de datos personales y, en particular, a aquellas que identifiquen que un tratamiento podría representar un alto riesgo para los derechos y libertades de los Titulares.

Cada área será responsable de evaluar, conforme a sus funciones y procesos, si un tratamiento específico amerita la realización de una EIPD. En caso de determinar que resulta pertinente elaborar una EIPD, la aplicación de esta Política y del procedimiento que en ella se describe será obligatoria de manera interna.

Aunque la elaboración de una EIPD no es un requisito legal conforme al marco normativo mexicano, Grünenthal adopta su realización como una buena práctica para fortalecer el principio de responsabilidad establecido en la LFPDPPP y prevenir posibles afectaciones a los derechos de los Titulares.

Términos y definiciones

Términos

Definición/Explicación

Aviso de Privacidad

Documento a disposición de la persona titular de la información de forma física, electrónica o en cualquier otro formato generado por Grünenthal, a partir del momento en el cual se recaben sus datos personales, con el objeto de informarle los propósitos del tratamiento de los mismos.

Base de datos

Conjunto ordenado de datos personales referentes a una persona identificada o identificable condicionados a criterios determinados, con independencia de la forma o modalidad de su creación, tipo de soporte, procesamiento, almacenamiento y organización.

Consentimiento

Manifestación de la voluntad libre, específica e informada de la persona titular de los datos mediante la cual se efectúa el tratamiento de los mismos.

Datos personales

Cualquier información concerniente a una persona identificada o identificable. Se considera que una persona es identificable cuando su identidad pueda determinarse directa o indirectamente a través de cualquier información

Datos personales sensibles

Aquellos datos personales que afecten a la esfera más íntima de la persona titular, o cuya utilización indebida pueda dar origen a discriminación o conlleve un riesgo grave para esta. De manera enunciativa más no limitativa se consideran sensibles los datos personales que puedan revelar aspectos como origen racial o étnico, estado de salud presente o futuro, información genética, creencias religiosas, filosóficas y morales, opiniones políticas y preferencia sexual.

Derechos ARCO

Son los derechos de Acceso, Rectificación, Cancelación, Oposición. Adicionalmente, se consideran los derechos de revocación de consentimiento y limitación de uso y/o divulgación de Datos Personales.

Términos

Definición/Explicación

Persona Encargada / Encargado

Persona física o jurídica que sola o conjuntamente con otra trate datos personales por cuenta de Grünenthal.

Ley / LFPDPPP

Ley Federal de Protección de Datos Personales en Posesión de Particulares, publicada en marzo de 2025.

Departamento Datos Personales /DDP

Es la entidad dentro de Grünenthal encargada de gestionar las solicitudes de ejercicio de derechos de los titulares en materia de protección de datos personales, conforme a la normativa aplicable y a las políticas internas de la

organización.

Responsable

Personas físicas o morales de carácter privado que llevan a cabo el tratamiento de datos personales, en este caso Grünenthal.

Titular(es)

La persona física a quien corresponden los datos personales.

Tratamiento

Cualquier operación o conjunto de operaciones efectuadas mediante procedimientos manuales o automatizados aplicados a los datos personales, relacionadas con la obtención, uso, registro, organización, conservación, elaboración, utilización, comunicación, difusión, almacenamiento, posesión, acceso, manejo, aprovechamiento, divulgación, transferencia o disposición de datos personales.

Enfoque del EIPD

Las EIPDs se fundamentan en un enfoque de análisis de riesgos asociado al tratamiento de datos personales en el contexto de nuevos productos, servicios, tecnologías o modelos de negocio, así como en la implementación de medidas necesarias para mitigar dichos riesgos. La elaboración de una EIPD debe entenderse como parte del proceso de gestión de riesgos inherente al tratamiento de datos personales, y no como una actividad aislada.

Un riesgo es un escenario que describe un posible acontecimiento y sus consecuencias, evaluado en términos de gravedad y probabilidad. A su vez, la gestión de riesgos comprende el conjunto de actividades coordinadas para dirigir y controlar a una organización en relación con dichos riesgos.

En este sentido, el concepto de probable alto riesgo se refiere a situaciones en las que el tratamiento de datos personales puede implicar un impacto significativo en los derechos y libertades de las personas. Estos riesgos no se limitan únicamente al derecho a la protección de datos personales o a la privacidad, sino que pueden extenderse a otros derechos fundamentales como:

Libertad de expresión

Libertad de pensamiento

Libertad de circulación

Prohibición de discriminación

Derecho a la libertad individual

Libertad de conciencia y religión

En línea con este enfoque basado en riesgos, es posible (y recomendable) realizar EIPD en cualquier operación de tratamiento, especialmente si se pretende alcanzar los más altos estándares en materia de protección de datos personales.

Cabe reiterar que, si bien la elaboración de EIPD no es legalmente obligatoria en el marco normativo mexicano, ello no exime a Grünenthal de su deber general de adoptar medidas que garanticen una adecuada gestión de los riesgos vinculados con el tratamiento de datos personales, conforme al principio de responsabilidad y el deber de seguridad previstos en la LFPDPPP.

Sobre la EIPD

Una EIPD es un proceso estructurado que permite:

Describir detalladamente el tratamiento de datos personales que se pretende llevar a cabo;

Evaluar la necesidad y proporcionalidad del tratamiento propuesto; y

Identificar, analizar y gestionar los riesgos potenciales para los derechos y libertades de los Titulares de los datos personales, proponiendo las medidas adecuadas para mitigarlos.

La EIPD es una herramienta que fortalece la rendición de cuentas, al permitir que Grünenthal documente y evidencie que ha identificado los riesgos asociados a un tratamiento de datos personales y que ha adoptado medidas concretas para mitigarlos. De esta forma, la EIPD no solo contribuye al cumplimiento de los principios y obligaciones establecidos en la LFPDPPP, sino que además facilita demostrar dicho cumplimiento ante los titulares, terceros y autoridades.

En este sentido, la EIPD permite a Grünenthal:

Cumplir con estándares más altos de protección de datos personales;

Promover políticas internas alineadas con criterios nacionales e internacionales; y

Fortalecer la toma de decisiones basada en evidencia y prevención de riesgos.

Además, al tener un carácter preventivo, la EIPD debe realizarse antes de iniciar un tratamiento de datos personales que represente un probable alto riesgo. Sin embargo, su aplicación no se agota en esta evaluación inicial del tratamiento. Será responsabilidad del área correspondiente verificar periódicamente si las condiciones generales del tratamiento se mantienen conforme a lo evaluado originalmente y, en caso de que se modifique alguna característica principal del tratamiento, realizar una nueva evaluación o actualizar la existente.

Finalmente, el resultado de la EIPD debe ser considerado como un insumo clave en la toma de decisiones estratégicas y operativas respecto a la viabilidad del tratamiento, así como en la definición de las medidas de seguridad y privacidad necesarias para su ejecución conforme a la normativa aplicable.

¿Qué aborda una EIPD?

Una EIPD puede aplicarse a diferentes escenarios de tratamiento, siempre que se mantenga un enfoque sistemático y se garantice la mitigación de riesgos para los derechos y libertades de los Titulares. Entre los casos más relevantes se encuentran:

Evaluación de una única operación de tratamiento

Una EIPD puede centrarse en una sola operación de tratamiento. No obstante, también puede abarcar un conjunto de operaciones similares que impliquen riesgos equivalentes. Esto resulta útil y eficiente cuando Grünenthal implemente, por ejemplo, una aplicación o plataforma común de tratamiento, o cuando varios responsables prevean el uso compartido de un entorno o herramienta tecnológica.

Evaluación conjunta de operaciones similares

Es posible realizar una única EIPD para múltiples operaciones que compartan características en cuanto a naturaleza, alcance, contexto, fines y riesgos. Esto evita duplicar evaluaciones cuando se utilizan tecnologías y procesos semejantes para recopilar y tratar el mismo tipo de datos. En estos casos, se puede elaborar una EIPD de referencia que sirva de base para todos los proyectos, siempre que se apliquen las medidas previstas y se justifique el uso de un único documento.

Cuando participen corresponsables, deberán establecer claramente sus funciones y obligaciones, precisando qué parte es responsable de cada medida de mitigación de riesgos. La información útil debe compartirse sin comprometer secretos comerciales, propiedad intelectual, información estratégica o seguridad.

Evaluación de productos tecnológicos.

Una EIPD también puede aplicarse a la evaluación de un producto tecnológico, como hardware o software, que pueda ser utilizado por distintos responsables para operaciones de tratamiento con riesgos relevantes.

En este caso, aunque el proveedor del producto pueda elaborar una EIPD de referencia, cada responsable deberá realizar su propia evaluación adaptada al uso específico que hará del producto. La información relevante deberá intercambiarse entre las partes de manera controlada, evitando revelar vulnerabilidades o información confidencial.

¿Qué aborda una EIPD?

Como ya se estableció en repetidas ocasiones en el presente documento, en México, la elaboración de una EIPD no es un procedimiento regulado para los particulares responsables del tratamiento, como es el caso de Grünenthal. Por lo tanto, se establecen los presentes lineamientos con base en estándares internacionales, mejores prácticas y metodologías reconocidas para su desarrollo.

¿Cuándo se debe hacer una EIPD?

Una EIPD deberá realizarse preferentemente antes de iniciar el tratamiento de datos personales, en las siguientes situaciones:

Cuando el tratamiento implique el manejo sistemático o masivo de datos que cuenten con una protección especial por parte de la normativa, como los datos sensibles. (Ejemplo: gestión centralizada de expedientes médicos de pacientes en todos los centros de atención de Grünenthal, que contengan diagnósticos, historial clínico y tratamientos prescritos).

Cuando el Responsable ceda datos personales a terceros (Ejemplo: envío de datos de médicos participantes en un programa de educación médica a una agencia externa encargada de la logística del evento).

Cuando la transferencia de datos se realice a países fuera de México (Ejemplo: envío de reportes de farmacovigilancia a la casa matriz en Europa para su análisis global).

Cuando se crucen datos de usuarios con información de otras fuentes, o se traten datos personales de forma masiva (Big Data) (Ejemplo: análisis combinado de encuestas a profesionales de la salud con datos de ventas y consumo de medicamentos para identificar tendencias terapéuticas).

Cuando el tratamiento tenga como finalidad la toma de decisiones sobre los Titulares que produzcan efectos jurídicos o consecuencias que puedan afectarles de manera significativa (Ejemplo: análisis de documentos e información de candidatos en el proceso de contratación de personal).

Cuando el propio tratamiento pueda impedir a los Titulares ejercer un derecho, acceder a un servicio o cumplir un contrato (Ejemplo: análisis de documentación e información para verificar la identidad de un paciente antes de

permitir su ingreso al programa de donaciones de Grünenthal).

Cuando se traten de forma significativa datos de menores de edad u otras personas en situación de vulnerabilidad (Ejemplo: tratamiento de datos de menores o de pacientes geriátricos que participen en estudios relacionados con medicamentos pediátricos y geriátricos, respectivamente).

Cuando el tratamiento tenga como objetivo predecir aspectos personales o elaborar perfiles de los Titulares (Ejemplo: creación de expedientes laborales.)

Cuando los datos obtenidos se utilicen para una finalidad más intrusiva que la originalmente prevista, o se empleen tecnologías especialmente invasivas para la privacidad (Ejemplo: estudios médicos a trabajadores)

Cuando se contacte con los Titulares de manera intrusiva (Ejemplo: él envió de comunicados con fines promocionales a Médicos).

Cuando se utilicen datos personales no disociados o no anonimizados de forma irreversible con fines estadísticos, históricos o de investigación científica (Ejemplo: investigación médica en el cual no se anonimiza la información)

Cuando existan riesgos específicos que puedan comprometer la confidencialidad, integridad o disponibilidad de los datos personales (Ejemplo: implementación de un sistema de almacenamiento en la nube para reportes de farmacovigilancia, sin contar con protocolos de cifrado y control de accesos robustos.)

¿Cuándo se está ante un tratamiento que implica un “alto riesgo”?

Evaluación o puntuación, incluida la elaboración de perfiles y predicciones.

Se refiere a tratamientos que impliquen el análisis sistemático de datos personales para evaluar aspectos como el rendimiento laboral, la situación económica, la salud, las preferencias o intereses personales, la fiabilidad, el comportamiento, la ubicación o los desplazamientos del Titular. Esto incluye la recolección de información proveniente de distintos ámbitos de su vida con el fin de generar un perfil integral o tomar decisiones automatizadas.

Ejemplo: una institución financiera que consulta bases de datos de referencia crediticia o de prevención de lavado de dinero para evaluar la solvencia de un cliente; una empresa de biotecnología que realiza pruebas genéticas para predecir el riesgo de enfermedades; o una compañía que crea perfiles de comportamiento y mercadotecnia basados en la navegación web y el historial de compras de sus usuarios.

Observación, monitorización, supervisión, geolocalización o control del Titular de forma sistemática y exhaustiva.

Incluye la recolección continua o recurrente de datos personales y metadatos mediante redes, aplicaciones,

dispositivos o en espacios de acceso público, así como el tratamiento de identificadores únicos que permitan reconocer de manera individual a los usuarios de servicios digitales.

Ejemplo: el uso de cámaras de videovigilancia con reconocimiento facial en un centro comercial; el rastreo de la ubicación de pacientes mediante aplicaciones móviles para seguimiento de tratamientos; o la recopilación de datos de navegación e interacción en plataformas de TV interactiva o aplicaciones de salud para elaborar patrones de comportamiento.

Observación sistemática.

Se refiere a tratamientos destinados a observar, supervisar o controlar de forma continua a los Titulares, incluidos aquellos que implican la recolección de datos a través de redes o la observación en zonas de acceso público. Este tipo de tratamiento reviste especial relevancia porque, en muchos casos, los Titulares pueden desconocer quién recopila sus datos, con qué finalidad o cómo serán utilizados, y porque puede ser imposible para ellos evitar ser objeto de dicha observación en determinados espacios.

Ejemplo: la instalación de cámaras de videovigilancia en áreas de atención al público en hospitales o farmacias; el monitoreo de comportamiento de pacientes en salas de espera mediante sensores; o el rastreo de dispositivos móviles dentro de un centro comercial para analizar patrones de movimiento.

Datos sensibles.

Comprende aquellos datos personales que afectan a la esfera más íntima del Titular o cuya utilización indebida pueda originar discriminación o conllevar un riesgo grave para su persona. Entre ellos se encuentran, por ejemplo, el origen racial o étnico, estado de salud presente y futuro, información genética, creencias religiosas, filosóficas o morales, afiliación sindical, opiniones políticas y preferencia sexual.

Más allá de esta definición, también pueden considerarse de alto riesgo ciertos datos que, sin estar expresamente categorizados como sensibles en la ley, impactan directamente derechos fundamentales o cuya vulneración puede ocasionar daños significativos, como datos de localización, información financiera susceptible de fraude, comunicaciones electrónicas privadas o información íntima registrada en aplicaciones personales.

Ejemplo: el tratamiento de expedientes de farmacovigilancia que contienen diagnósticos médicos, historial de tratamientos y reacciones adversas de pacientes pediátricos o geriátricos.

Tratamientos que impliquen el uso de datos biométricos.

Incluyen el tratamiento de propiedades físicas, fisiológicas, de comportamiento o rasgos de la personalidad, atribuibles a una sola persona y que son medibles. Entre ellos se encuentran, por ejemplo, huellas digitales, reconocimiento facial, patrones del iris o la retina, geometría de la mano o de los dedos, estructura de las venas, forma de las orejas, textura de la piel, ADN, composición química del olor corporal, patrón vascular o ritmo

cardíaco.

Estos datos, por su naturaleza, permiten la identificación única de una persona y, en caso de uso indebido, pueden derivar en graves riesgos para su privacidad y seguridad.

Ejemplo: implementación de un sistema de control de acceso a laboratorios mediante reconocimiento facial y escaneo de huella digital de investigadores y personal autorizado.

Tratamientos que impliquen el uso de datos genéticos.

Incluyen el tratamiento de información hereditaria relativa a las características biológicas de una persona, obtenida mediante el análisis de muestras biológicas como sangre, saliva, tejido, cabello u otros fluidos corporales. Estos datos pueden revelar información única e inmutable sobre la identidad, predisposición a enfermedades o características hereditarias, y su uso indebido puede tener consecuencias graves para la privacidad, la salud y otros derechos fundamentales del Titular.

Ejemplo: análisis de ADN de pacientes para determinar predisposición genética a desarrollar ciertas enfermedades como cáncer o trastornos neuromusculares.

Tratamientos que impliquen la asociación, combinación o enlace de registros de bases de datos de dos o más tratamientos con finalidades diferentes o por responsables distintos.

Se refiere a la integración de información personal proveniente de distintas fuentes o sistemas para crear un expediente o perfil más completo del Titular. Este tipo de tratamiento puede aumentar de forma significativa el riesgo de invasión de la privacidad, ya que combina datos que originalmente se recabaron para propósitos distintos y bajo contextos específicos.

Ejemplo: un hospital que combina la base de datos de historiales clínicos con la de un proveedor externo de seguros médicos para evaluar la viabilidad de cobertura de un tratamiento, utilizando información originalmente recabada con fines diferentes.

Tratamiento de datos a gran escala.

Se refiere a operaciones de tratamiento que, por su magnitud o alcance, pueden generar un riesgo elevado para los derechos y libertades de los Titulares. Para determinar si un tratamiento se considera a gran escala, deben evaluarse factores como:

El número total de Titulares afectados, ya sea como cifra absoluta o en proporción a la población objetivo.

El volumen de datos o la diversidad de categorías de datos procesados.

La duración o permanencia del tratamiento.

El alcance geográfico de la actividad de tratamiento.

La asociación o combinación de conjuntos de datos procedentes de diferentes operaciones o responsables, en contextos que excedan las expectativas razonables del Titular.

Ejemplo: una cadena hospitalaria que centraliza en un único sistema la información clínica, administrativa y de facturación de millones de pacientes de distintas sucursales ubicadas en varios países, con la finalidad de implementar un sistema unificado de gestión y análisis de datos.

Datos relativos a Titulares vulnerables.

Este criterio se refiere al tratamiento de datos personales de personas que, por su situación, requieren una especial protección debido al desequilibrio de poder existente frente al responsable del tratamiento. Esto implica que podrían no estar en condiciones de autorizar o denegar el tratamiento de sus datos, o de ejercer plenamente sus derechos. Entre los Titulares vulnerables se incluyen, de forma enunciativa, a:

Menores de edad.

Empleados en relación de subordinación.

Personas con enfermedades mentales.

Solicitantes de asilo o refugiados.

Personas adultas mayores.

Pacientes en tratamiento médico.

Ejemplo: un hospital que recaba y gestiona el historial clínico y datos de contacto de pacientes pediátricos y geriátricos que participan en programas de investigación médica para el desarrollo de nuevos tratamientos.

. Uso innovador o aplicación de nuevas soluciones tecnológicas u organizativas.

Se refiere a la implementación de tecnologías, herramientas o procesos novedosos que impliquen nuevas formas de obtención, tratamiento o utilización de datos personales, y que puedan conllevar un alto riesgo para los

derechos y libertades de los Titulares. Esto incluye, de manera enunciativa, la combinación de distintos métodos de identificación biométrica, el uso de inteligencia artificial para toma de decisiones automatizadas, o la integración de dispositivos del «Internet de las Cosas» (IoT) en actividades que recolectan datos de forma constante.

Ejemplo: la implementación de un sistema de control de acceso en un hospital que combine reconocimiento facial y escaneo de huella dactilar para el ingreso a áreas restringidas, o el uso de dispositivos médicos conectados a internet que recopilan y transmiten datos de salud de los pacientes en tiempo real.

En la mayoría de los casos, el Responsable del tratamiento podrá determinar que una operación que cumpla con al menos dos de los criterios de alto riesgo requerirá la realización de una EIPD. De manera general, mientras mayor sea el número de criterios que cumpla el tratamiento, mayor será la probabilidad de que represente un riesgo significativo para los derechos y libertades de los Titulares, lo que hará necesaria la elaboración de una EIPD, independientemente de las medidas que el Responsable contemple adoptar para mitigarlo.

No obstante, en determinadas circunstancias, el Responsable podrá considerar que un tratamiento que cumpla únicamente con uno de los criterios de alto riesgo es suficiente para justificar la realización de una EIPD, debido a la naturaleza, el alcance o el contexto específico de dicho tratamiento.

A continuación, se presentan ejemplos que ilustran cómo pueden aplicarse estos criterios para evaluar si una operación de tratamiento concreta requiere una EIPD:

Ejemplos de tratamiento

Posibles criterios que aplican para determinar el riesgo

¿Requiere de EIPD?

Un hospital que trata los datos genéticos y sanitarios de sus pacientes (siste

Datos sensibles o datos muy personales.

Datos relativos a Titulares vulnerables.

Tratamiento de datos a gran escala.

Si

El uso de un sistema de cámaras para controlar el comportamiento al volante

del tratamiento contempla el uso de un sistema inteligente de análisis de vídeo para reconocer matrículas automáticamente.

Observación sistemática.

Uso innovador o aplicación de soluciones tecnológicas u organizativas.

Una empresa que observa sistemáticamente las actividades de sus empleados en el puesto de trabajo de los empleados, la actividad en internet, etc.

Observación sistemática.

Datos relativos a Titulares vulnerables.

La recogida de datos de los medios sociales públicos para elaborar perfiles.

Evaluación o puntuación.

Tratamiento de datos a gran escala.

Asociación o combinación de conjuntos de datos.

Datos sensibles o datos muy personales:

Una institución que crea una base de datos nacional de calificación crediticia.

Evaluación o puntuación.

Toma de decisiones automatizada con

efecto jurídico significativo o similar.

Impide a los Titulares ejercer un derecho o utilizar un servicio o ejecutar un contrato.

Datos sensibles o datos muy personales:

Conservación con fines de archivo de datos personales y sensibles seudónimos vulnerables de proyectos de investigación o ensayos clínicos.

Datos sensibles.

Datos relativos a Titulares vulnerables.

Impide a los Titulares ejercer un

derecho o utilizar un servicio o ejecutar un contrato.

Un tratamiento de «datos personales de pacientes o clientes por un solo médico abogado»

Datos sensibles o datos muy personales.

Datos relativos a Titulares vulnerables.

Una revista en línea que use una lista de distribución para enviar un resumen a suscriptores.

Tratamiento de datos a gran escala.

No

Un sitio web de comercio electrónico que muestra anuncios de piezas de coche elaboración de perfiles limitada basada en elementos vistos o adquiridos en

Evaluación o puntuación.

Finalmente, en caso de que Grünenthal determine que un tratamiento de datos personales probablemente no entraña un alto riesgo, aun cuando se actualice uno o varios de los criterios previamente descritos, será indispensable justificar y documentar las razones por las que no se lleva a cabo una EIPD.

Dicha justificación deberá quedar debidamente registrada e incluir, cuando corresponda, las observaciones y opiniones emitidas por el Departamento de Datos Personales.

¿Cuándo no es necesario realizar una EIPD?

No será necesaria la realización de una EIPD en los siguientes supuestos:

Cuando no sea probable que el tratamiento implique un alto riesgo para los derechos y libertades de las personas físicas.

Cuando la naturaleza, el alcance, el contexto y los fines del tratamiento sean muy similares a otro tratamiento para el cual ya se haya realizado una EIPD. En estos casos, podrán utilizarse los resultados obtenidos en la evaluación previa.

Tratamientos necesarios para el cumplimiento de una obligación legal, el desarrollo de una misión de interés público o el ejercicio de facultades conferidas a Grünenthal.

Tratamientos exigidos por ley y vinculados a la gestión interna de personal en pequeñas y medianas empresas, con finalidades de contabilidad, gestión de recursos humanos y nóminas, seguridad social y salud laboral, sin incluir datos de clientes.

Características mínimas de una EIPD

Como criterio orientador, y tomando como referencia las directrices internacionales y la “Guía para la elaboración de Evaluaciones de Impacto a la Privacidad” del INAI, una EIPD debe incluir, al menos, los siguientes elementos:

Descripción sistemática de las actividades de tratamiento previstas, incluyendo su alcance, contexto y fines.

Evaluación de la necesidad y proporcionalidad del tratamiento en relación con la finalidad perseguida.

Análisis de riesgos para los derechos y libertades de los Titulares derivados del tratamiento.

Medidas previstas para mitigar los riesgos, incluyendo garantías, controles, medidas de seguridad y mecanismos que aseguren la protección de los datos personales.

Las etapas de una EIPD se pueden estructurar con el flujo de análisis y acciones a seguir en la ejecución de una EIPD:

Contexto

a. Describir el tratamiento de datos personales: Consiste en detallar la naturaleza y finalidad del tratamiento, describiendo de forma precisa el ciclo de vida y el flujo de los datos personales, desde su obtención hasta su supresión. Esta descripción debe incluir:

Los tipos de datos personales tratados.

Los intervinientes y terceros que participan en el tratamiento.

Los sistemas, aplicaciones o herramientas utilizadas.

Cualquier otro elemento relevante que forme parte del proceso.

El análisis debe partir de un conocimiento exhaustivo de todo el ciclo de vida de los datos y de los actores involucrados en cada fase, desde el inicio de la recolección hasta el final de su conservación o eliminación.

El ciclo de vida de los datos puede dividirse en las siguientes etapas:

b. Evaluar la necesidad y proporcionalidad del tratamiento: Consiste en analizar la base de legitimación, la finalidad y la pertinencia del tratamiento que se pretende llevar a cabo. Este análisis permite determinar si la actividad es adecuada y equilibrada respecto a los derechos y libertades de los Titulares.

Para ello, se recomienda aplicar los tres elementos del denominado juicio de proporcionalidad:

Juicio de idoneidad: Verificar si el tratamiento propuesto es apto para lograr la finalidad prevista.

Juicio de necesidad: Comprobar si no existe una medida menos intrusiva que permita alcanzar el mismo objetivo con igual eficacia.

Juicio de proporcionalidad en sentido estricto: Ponderar si los beneficios que aporta el tratamiento superan los posibles perjuicios o afectaciones a otros bienes o derechos en conflicto.

Contexto

La gestión de riesgos es el proceso de identificar, analizar y valorar la probabilidad e impacto derivados de la posibilidad de que se materialice un riesgo con el objetivo de establecer las acciones preventivas, correctivas y reductivas que permitan minimizar el nivel de exposición al riesgo.

Identificar amenazas y riesgos: Identificación de las amenazas y riesgo potenciales para los Titulares expuestos las actividades de tratamiento.

Evaluar los riesgos: Evaluación de la probabilidad y el impacto de que se mat

expuesta la organización. Con relación a los riesgos para la seguridad de la información se recomienda:

Hacer uso de los Análisis de Brechas (procedimiento establecido en la Política de sistema de Gestión de Seguridad) para registrar y documentar las medidas de seguridad existentes y faltantes, que ayuden a minimizar la ocurrencia y el impacto de vulneraciones a la seguridad de los datos personales

Consultar las políticas internas y globales de Grünenthal sobre protección de datos personales y seguridad de la información.

Tratar los riesgos: Consiste en implementar una respuesta ante los riesgos identificados con el objetivo de reducir su probabilidad de ocurrencia y el impacto de que se materialicen, hasta alcanzar un nivel de riesgo aceptable que permita garantizar los derechos y libertades de las personas físicas.

En materia de seguridad de la información, se recomienda consultar los siguientes materiales:

Recomendaciones para el manejo de incidentes de seguridad de datos personales, en el que se describen procesos y controles propuestos por el INAI para establecer un plan de respuesta a incidentes, particularmente para mitigar vulneraciones a la seguridad de los datos personales.

Metodología de análisis de riesgo BAA, que evalúa el riesgo de los datos personales considerando tres factores: (i) el beneficio potencial para el atacante, (ii) la accesibilidad de la información, y (iii) la posible anonimidad del atacante.

Conclusión y validación

a. Plan de acción y conclusiones: Documento que presenta los resultados de la EIPD, describiendo de forma detallada las conclusiones alcanzadas y el plan de acción correspondiente. Dicho plan debe contemplar las medidas de control que se implantarán para gestionar los riesgos identificados, con el fin de garantizar la protección de los derechos y libertades de las personas físicas.

Adicionalmente, deberá establecerse un proceso de supervisión y revisión de la implementación o puesta en marcha del nuevo tratamiento, con el objetivo de verificar que las medidas de control descritas en el plan de acción se apliquen correctamente y resulten eficaces en la mitigación de los riesgos.

Nota: La EIPD debe concebirse como un proceso de mejora continua, revisándose cada vez que se modifique o actualice cualquier aspecto relevante de las actividades de tratamiento.

Si se producen cambios en la descripción del tratamiento o surgen nuevas amenazas o riesgos (derivados de la experiencia o de factores previamente desconocidos) que afecten a los fines o medios del tratamiento, se deberá realizar una nueva evaluación de impacto, elaborar un nuevo informe y definir un plan de acción con las medidas de control correspondientes.

En caso de que los cambios no sean significativos y no generen nuevas amenazas o riesgos para los derechos y libertades de los titulares, igualmente deberá efectuarse una valoración de dichos cambios y documentar de manera clara la no necesidad de implantar medidas de control adicionales

Todo responsable que implemente una EIPD podrá documentar cada una de la finalidad de generar evidencia con relación al cumplimiento de las obligaciones de los datos personales.

Por lo anterior, resultara de suma importancia mantener evidencia de todas y cada una de las actividades realizadas, puesto que estas sustentara n las conclusiones y medidas de seguridad administrativas que se determinen para desarrollar un adecuado tratamiento de datos personales.

Actores que pueden participar en la EIPD

En primer lugar, es importante mencionar que corresponde al responsable del tratamiento (Grünenthal) la obligación de realizar la EIPD y no específicamente al Departamento de Datos Personales (DPP).

Desde un punto de vista práctico, existen varias figuras, con diferentes roles y responsabilidades, que pueden participar en la realización de una EIPD; entre estas figuras, la del DPD supone un valor añadido en el desarrollo de la EIPD, aportando garantías para los derechos y libertades de los Titulares. Por tanto, el DPP proporciona el asesoramiento necesario al responsable del tratamiento para el adecuado desarrollo y ejecución de una EIPD.

La matriz de asignación de responsabilidades o RACI (acrónimo formado por las iniciales de los tipos de responsabilidad (Responsable, Accountable, Consulted, Informed)) es un método utilizado en la gestión de proyectos para relacionar actividades con individuos o equipos de trabajo. RACI establece las siguientes figuras de responsabilidad:

Responsable (R): Responsable de realizar la tarea.

Accountable (A): Responsable de que la tarea se realice, sin necesidad de ser quien la ejecute, y de rendir cuentas sobre su ejecución.

Consulted (C): Figura que debe ser consultada para la realización de la tarea.

Informed (I): Figura que debe ser informada sobre la realización de la tarea.

Con base en la metodología RACI, a continuación se proporcionan orientaciones y un ejemplo de cómo se podrían establecer las responsabilidades en el proceso de realización de una EIPD.

Es importante destacar que el término Responsable no implica que el área indicada para cada fase de la EIPD sea necesariamente quien deba ejecutar las tareas asociadas, por lo que es posible que se apoye en otras áreas, expertos, recursos externos, entre otros. Un aspecto relevante en el desarrollo de una EIPD es involucrar a aquellas figuras que tengan un conocimiento profundo del tratamiento.

La obligación de realizar una EIPD corresponde al responsable del tratamiento (Grünenthal), con el apoyo y colaboración del encargado del tratamiento, si lo hubiese, y, en su caso, del DDP. Adicionalmente, el personal encargado de la seguridad, el área de tecnología, el área jurídica o incluso distintos responsables de áreas implicadas en el tratamiento pueden ser requeridos durante el proceso de evaluación.

Otra buena práctica en el proceso de elaboración de la EIPD es definir y documentar otras funciones y responsabilidades específicas, tomando en consideración la política interna y los procesos de la organización, tales como recabar el asesoramiento de expertos relacionados con la materia.

En lo que respecta a la ejecución de la EIPD, esta puede ser realizada por personal interno o externo de la organización, sin que ello exima al responsable del tratamiento de cumplir con sus obligaciones, asegurando que se lleve a cabo de forma adecuada y que se implanten los controles y medidas de seguridad resultantes de la evaluación.

La participación del DDP en la elaboración debe entenderse como una función de asesoramiento, considerando que, entre sus funciones, está la de responder a las consultas que surjan y monitorizar el proceso.

NOTA: Es fundamental que, a nivel interno en cada Entidad, exista una comunicación fluida con las áreas involucradas en las operaciones del tratamiento con el objetivo de obtener informaciones relevantes sobre el ciclo de vida de los datos asociados al tratamiento. Será vital poder describirlo de sus vínculos con otros tratamientos y llevar a cabo la evaluación de riesgos disponiendo de toda la información necesaria sobre lo que este realiza.

Adicionalmente, la consulta con terceras partes encargadas de las actividades de tratamiento proporciona a la Entidad la oportunidad de obtener una visión completa de cómo se verán afectadas las actividades de tratamiento delegadas en terceros.

En resumen, los actores involucrados en la puesta en operación de una EIPD

Supervisión y examen

Como etapa final del proceso, se prevé que Grünenthal, como responsable del tratamiento, establezca los mecanismos necesarios para realizar una evaluación de los resultados de la EIPD, con la finalidad de identificar las acciones a seguir y, en su caso, que estas sean supervisadas por el área correspondiente dentro de su organización interna.

Se sugiere que, una vez identificados los posibles riesgos que conlleve el tratamiento de datos personales que se pretenda implementar, se determine si será necesario consultar al INAI con el fin de recibir apoyo técnico y las recomendaciones respectivas.

Índice histórico

n/a

Revisión/n.º de documento

Descripción de los cambios

01

Nuevo documento